

HelixVPN Spec — Refinement Punch-List (pass 1 → pass 2/3)

HelixVPN Spec — Refinement Punch-List (pass 1 → pass 2/3)

Revision: 3 Last modified: 2026-07-04T12:00:00Z Rev 3
(2026-07-04): Recorded the **enterprise-hardening pass** (Pass 2/3 proper) — see the new "Enterprise-hardening pass (2026-07-04)" section below. R5 (task/subtask tier asymmetry) is now RESOLVED. R1/R2/R3/R4/R6 remain as previously closed/recorded (unchanged by this pass).

This spec set is **pass 1** of the operator's planned 2-3 refinement passes. It was generated by a multi-agent workflow from the 16 research docs + the cross-document synthesis. The adversarial completeness + technical-consistency review returned **go=false** on internal-consistency grounds (the content is substantively complete; the source-coverage ledger is accurate, not bluffed; zero placeholders/TODO/TBD). This file records every finding so nothing is lost going into the next pass (§11.4.118 / §11.4.134 / §11.4.6 — honest, no hidden gaps).

Status of pass 1

- **13 spec docs + coverage ledger written** (≈11.7K lines): SPECIFICATION.md spine, 00-11 topical/WBS docs, 99 source-coverage ledger.
- All 16 source docs cited; all open decisions D1-D7 surfaced with recommendations.
- 46 Mermaid diagrams, SQL DDL, Podman/Docker/K8s manifests embedded.

FIXED

- **F1 — Spine navigation (was the GO-blocker).**
SPECIFICATION.md §10 INDEX and §7 owning-doc pointers (+ §6

and the §9 decision register) referenced an idealized filename scheme (00_PRODUCT_AND_REQUIREMENTS.md ...) that does not exist on disk. Rewritten to point at the real files (00-product-scope-and-principles.md ... 99-source-coverage-ledger.md) with correct owning-doc mapping (Transport trait → 01; WatchNetworkMap → 02; FFI → 03).

- **F2 — Proto package unified (resolves R2).** The Coordinator service proto is now helix.coordinator.v1 across SPECIFICATION.md, 02-control-plane.md, and 11-deep-research-appendix.md (billing stays helix.billing.v1). Schema-first zero-drift restored.
- **F3 — D8 added to ledger (resolves R3).** 99-source-coverage-ledger.md decision cross-check now lists D1-D8 (added D8 licensing/positioning) and the header/footer say "8".

OPEN for pass 2 (worklist)

- **R1 — Deep web research NOT performed (rate-limited).** The 10 research angles (wireguard, masque, hysteria2, mullvad, flutter_ffi, ios_android, go_cp, podman_k8s, pki_pq_nat, daita_test) all failed on the transient server rate-limit; 11-deep-research-appendix.md honestly marks every external fact UNVERIFIED (no web access). **Pass 2 MUST run the deep research (§11.4.150/§11.4.99) when rate-limits clear** and replace the UNVERIFIED markers with cited (URL + access-date) facts; re-validate version pins. **Pass-2 status (2026-06-25): INTERMITTENT, not total — a 2-agent probe found the throttle is flaky. RESOLVED (mostly): 9 of 10 angles now verified against real cited web sources (masque, hysteria2, mullvad, flutter_ffi, ios_android, go_cp, podman_k8s, pki_pq_nat, daita_test — ~130 KB cited corpus in v09-research/research-*.md); 11-deep-research-appendix.md rewritten from that corpus. ONLY wireguard remains UNVERIFIED (kept rate-limited) — re-run that one angle when the throttle next clears.**
- **R2 — Proto package name inconsistent.** RESOLVED — see F2 above.
- **R3 — Decision D8 (licensing/positioning).** RESOLVED — see F3 above.
- **R4 — doc-99 identity.** SPECIFICATION §10 originally promised "99 = consolidated Glossary/Decisions/References"; the actual 99 is the source-coverage ledger (glossary lives in SPECIFICATION §11, decision register in §9). Reconciled in F1, but pass 2 may choose to split a dedicated 99_GLOSSARY_DECISIONS_REFERENCES.md if preferred.
- **R5 — Task→subtask tier asymmetry. RESOLVED (2026-07-04).** The 3-tier epic→task→subtask breakdown for Phases 1-3 already existed on disk in v07-execution/subtask-deepening-p1.md, -p2.md, -p3.md (full .k-level breakdowns with acceptance/tests/complexity) — but was **orphaned**: nothing in

07/08/09-*.wbs.md pointed to it, so a reader had no way to discover the deeper granularity existed. Fixed by cross-referencing each WBS task to its corresponding subtask-deepening section rather than duplicating the content. Phase 0's own WBS (06-...) was independently re-verified to still have concrete acceptance evidence per gate (G1-G6).

- **R6 — Ledger-disclosed source gaps** (honestly flagged, not hidden):
 - G1 [03_ZAI] disaster-recovery / RTO-RPO not consolidated into a runbook section — OPEN, recommended for a Phase-2 HA/DR revision (08 or 05).
 - G2 [06_GRK] sing-box framework rejection rationale — RESOLVED: recorded in 99-ledger (Go framework conflicts with Rust-core D2 + iOS memory ceiling; custom Rust helix-transport gives byte-for-byte client↔edge reuse).
 - G3 [09_GCT] Fyne rejection rationale — RESOLVED: recorded in 99-ledger (Flutter is the only toolkit reaching all 8 platforms + shared design system; Fyne is desktop-only).

Expansion waves (nano-detail volumes per MASTER_INDEX)

- **V2 Data-Plane** 13 docs (v02-data-plane/), review go=true. Committed 7d748b3.
- **V3 Control-Plane** 13 docs (v03-control-plane/), 3 contradictions fixed to GO. Committed 5f43dae.
- **V4 Clients** 12 docs (v04-client/). R7 FFI-surface contradiction RESOLVED 2026-06-25 (helix-core-rust.md aligned to canonical ffi-surface.md). Review GO-blocker cleared.
- Citation paths normalized repo-wide: scratchpad/kb/* → in-repo v09-research/* so every [research-*]/[SYNTHESIS] reference resolves (one straggler: v02-data-plane/wireguard-core.md).
- **R7 — V4 FFI-surface contradiction. RESOLVED (2026-06-25, by hand — no agent).** ffi-surface.md is canonical owner; helix-core-rust.md aligned to it: (a) enum-name reconciled — FfiTunnelStatus kept as the actual Rust identifier; ffi-surface.md's path-qualified ffi::TunnelStatus documented as the SAME type (note added to both docs); (b) status_stream now returns Result<(), CoreError> in both (+ fan-out / re-emit prose aligned); (c) every FFI verb returns typed Result<_, CoreError> (was anyhow::Result) — anyhow stays orchestrator-internal, converted at the boundary via From impls; (d) CoreError unified to the 7-variant {NotStarted, AlreadyStarted, Config, Auth, HostFatal, BadFd, Internal

} (helix-core's Busy→AlreadyStarted, TunAttach→BadFd, MapParse→Config, Orch→folded); (e) apply_map added to ffi-surface.md §2 + F1 ownership row (+ MapApplied DTO); (f) footer already clean (no scratchpad/kb/ paths). V4 review GO-blocker cleared.

WEEKLY-LIMIT STOP (2026-06-25) → RESUMED (2026-06-25)

The account hit its weekly usage limit mid-V4; on resume the limit had cleared. R7 fixed by hand (no agent). Operator added a CRITICAL mandate (2026-06-25): **OpenDesign (§11.4.162) must be the design system for ALL apps, documented in full depth, and shipped as a fully decoupled reusable submodule (vasic-digital/helix_design)** — all screens, all reusable components, light+dark color schemes, the whole design system, every token form (JSON/CSS/Dart/Swift/Kotlin/ArkTS) ready for direct incorporation across all 8 platforms. This elevates the design system from one V4 sub-doc to its own **Volume 10 — Design System (OpenDesign)** in MASTER_INDEX. Resume order: V10 Design System → retry wireguard research → V5 Security → V6 Deploy → V1 Product → V7 Execution → V8 Testing → V0 Meta. Same batched-≤4-subagent + adversarial-review + commit-per-volume pattern (rate-limit lesson).

Volume 10 — Design System (OpenDesign) — GENERATED + REVIEWED (2026-06-25/26)

14 nano-detail docs in v10-design/ (~11,300 lines), generated by batched-≤4 subagents (§11.4.103) + adversarial review (§11.4.125/.142) reconciled to **clean GO, zero findings** (§11.4.134): 00-overview-and-submodule (750), opendesign-foundation (518), design-tokens (715), color-system (502), typography-iconography-motion (~430), token-export-pipeline (~560), component-library (1523, ~30 components), screens-client (~1270, 18 screens), screens-console (~790, 11 screens), screens-connector (~600, 5 screens), ux-flows-and-interaction (1032, 7 flows), platform-adaptation (887, 8 platforms), visual-regression-and-qa (808, 13 gates), assets-and-deliverables (891, 9 resource classes). Review findings F1–F5 all fixed (hex/token-name disclaimers, 5→7 projection attribution corrected to the Rust StatusProjector per ffi-surface §3.2, dangling sibling ref softened). **NOT YET COMMITTED — blocked on the disk condition below.**

D-OD-1 (OPERATOR DECISION, surfaced — non-blocking, safe default taken per §11.4.101)

Live web research (§11.4.99) found `nexu-io/open-design` is a **local-first generative-design authoring/refinement app** (DESIGN.md + tokens.css + od CLI + MCP) — NOT an npm token-dependency and it does NOT emit Dart/Swift/Compose/ArkTS/C-Qt. This does not match §11.4.162's literal "install as a project dependency / use its design tokens" phrasing. **Safe default adopted (reversible — docs only):** OpenDesign = the mandatory design *authoring/refinement* layer; the decoupled vasic-digital/helix_design submodule owns the canonical tiered JSON token source + the polyglot exporters OpenDesign cannot produce. §11.4.162's INTENT (OpenDesign as the design system) is satisfied. **Operator may (a) confirm this interpretation, (b) direct extending OpenDesign upstream (§11.4.74) to add token-export, or (c) flag the §11.4.162 wording for a §11.4.26 constitution refinement.** Recorded for confirmation; the loop did not idle on it.

ENVIRONMENT BLOCKER (operator-only) — /private/tmp full (ENOSPC)

The harness temp/scratch partition `/private/tmp/claude-501` is FULL — every Bash call fails with ENOSPC creating its output-capture file (culprit: a stale/parallel session dir `ad838599-.../s/tasks/`). Bash is the ONLY tool that can delete files, and it cannot run on a full disk → I cannot self-resolve (§11.4.21 exhaustion: no non-Bash deletion path exists). **All work is SAFE on /Volumes/T7 (separate device) — R7 + 14 V10 docs are complete + reviewed.** Only Bash-dependent steps (the `commit_all.sh` commit + push of V10) are blocked. Remediation = operator frees /private/tmp (e.g. `rm -rf /private/tmp/claude-501/*/[0-9a-f]*-*/tasks` 2>/dev/null or clear the temp partition), then I commit V10 and continue V5 → V6 → V1 → V7 → V8 → V0.

Volume 5 — Security & Privacy — GENERATED (2026-06-26) + wireguard research closed

8 nano-detail docs in `v05-security/` (~5,160 lines): threat-model (~545, STRIDE+LINDDUN), zero-trust-and-default-deny (~560), identity-and-enrollment (620), pki-and-certs (690), post-quantum (743, ML-KEM hybrid via WG PSK slot), no-logging-as-code (727, schema-lint gate), kill-switch-and-dns-leak (~615, per-OS firewall SM), audit-and-compliance (~660). **R1 CLOSED:** `v09-research/research-wireguard.md` (511 lines, cited) written + `11-deep-research-appendix.md` updated (all 10 angles now verified, rev→3). **V5**

volume-level adversarial review PENDING — run it just before commit (commit is disk-blocked below). Every measured-latency claim marked as a TARGET (§11.4.6); UNVERIFIED markers disciplined (Rosenpass Kyber-vs-ML-KEM status, ML-KEM byte sizes, per-OS firewall gaps, WG whitepaper PDF unreachable — re-confirmed from alt sources).

Enterprise-hardening pass (2026-07-04) — Pass 2/3, all volumes

An independent deep gap-analysis + direct hardening pass was executed across the **entire** docs/research/mvp/ corpus in scope (131 markdown files: the 16 top-level final/ chapters, all ~140 vNN-* nano-detail docs across Volumes 0-10, and the 5 04_VPN_CLD source documents), dispatched as 16 parallel file-scoped review-and-fix passes plus a foreground pass on the spine docs (SPECIFICATION.md, MASTER_INDEX.md, this file, 99-source-coverage-ledger.md). This closes the "adversarial reviews still owed for V1/V6/V7/V8/V0" item and independently re-verifies V2/V3/V4/V5/V10 (previously reviewed to GO) rather than trusting the label — several real defects were found even in the already-reviewed volumes, proving the re-verification was worth doing.

Real defects found and fixed (not padding — every volume was checked against its own already-high bar first, and the majority of files needed only a revision-header bump because they were already correct):

1. **PKI CA-rotation security gap** (v03-control-plane/svc-pki.md) — scheduled rotation and compromise-triggered rotation were conflated under one 24h trust-overlap window, meaning a **compromised** issuing CA would have stayed trusted for up to 24h. Split into two distinct paths (safe 24h-overlap scheduled rotation vs. zero-overlap compromise rotation with immediate ca.issuing.compromised event + fleet-wide force-revoke-and-re-enroll).
2. **Rust FFI-boundary contradiction** (v04-client/helix-core-rust.md) — the spec claimed both catch_unwind-style panic recovery AND workspace-wide panic=abort, which are mutually exclusive in Rust (abort terminates before any unwind/catch can run). Replaced with an honest corrected contract: no panic is caught at the FFI boundary; mitigation is lint-enforced defensive coding (deny unwrap/expect/panic/indexing in helix-ffi), and a genuine bug aborts the host process — stated as an accepted, explicit tradeoff, not hidden.
3. **QUIC anti-amplification gap** (v02-data-plane/transport-masque-quic.md) — the public :443/udp MASQUE edge listener had no stated defense against spoofed-source reflection amplification (RFC 9000 §8.1's 3× limit). Added.

4. **Reconcile-reliability gap** (v03-control-plane/data-model-ddl.md, reconciliation-flow.md) — a crash between the Postgres commit and the Redis XADD could silently drop a reconcile trigger with no schema to prevent it. Added a transactional outbox table + sweeper.
5. **Rate-limiting/DDoS resilience and a resource-sizing/cost model were genuinely absent anywhere in the corpus** — both added at the deployment layer (05-repo-layout-tooling-and-helix-ecosystem.md §7.5, v06-deploy/ha-and-multiregion.md §10), distinguishing control-plane API rate limiting from data-plane volumetric/handshake-flood resilience, and the DDoS *test strategy* for validating it (v08-testing/ddos.md).
6. **Protobuf versioning policy and zero-downtime schema-migration guidance** were missing — added (v03-control-plane/protobuf-spec.md §9, data-model-ddl.md §8.4).
7. **Multi-replica coordinator horizontal scaling** was a one-line unexamined claim ("coordinators are stateless") — expanded into a worked topology with an honestly-flagged open design question (fan-out vs. graph-apply consumption semantics), not silently resolved.
8. **Three internal status-drift contradictions** self-corrected within their own volumes: audit-and-compliance.md (D-AC-1 shown both resolved and open in different sections of the same file), opendesign-foundation.md (D-OD-1 shown open one day after decision-register.md recorded it operator-confirmed), and threat-model.md (a dangling §10 R-CONN cross-reference with no matching row).
9. **A numeric contradiction between the spine and a WBS:** SPECIFICATION.md §8.2 said Phase-2 regional failover is "< 30s"; 08-phase2-parity-wbs.md's instrumented **P2-SLO3** target is "< 3s". Reconciled in SPECIFICATION.md Rev 2 (the WBS's tighter, measured figure wins).
10. **R5 resolved** (see the updated worklist entry above) and the MASTER_INDEX.md "Outstanding quality items" list corrected (items (a)/(c)/(d) were stale; see MASTER_INDEX.md Rev 5).

Per-volume one-line summary (full detail in each touched file's own Revision changelog): V0-meta (glossary/traceability cross-checked, enterprise-NFR traceability rows added), V1-product (NFR gaps for scaling/HA/secrets/DDoS/cost/migration added as new numbered NFRs, journeys got sequence diagrams), V2-data-plane (anti-amplification + resource-exhaustion accounting added; Transport-trait spine-drift flagged), V3-control-plane (outbox, protobuf versioning, multi-replica scaling, rate limiting, CA-rotation split, MSP workflow added), V4-client (FFI panic contradiction fixed, backpressure policy named), V5-security (dangling ref + D-AC-1 consistency + PQ downgrade resistance fixed), V6-deploy (rate-limiting/DDoS + cost model + zero-downtime rollout added — see item 5), V7-execution (R5 resolved, phase-gate-failure protocols added to all WBS docs, dependency graph verified), V8-testing (explicit "tests-passing ≠ proof of working feature" requirement made first-class across every test-

type doc), V9-research (9 of 10 dossiers missing revision headers fixed; citation consistency independently re-verified, no contradictions found), V10-design (D-OD-1 staleness fixed; TopologyGraph stale-state + exit-picker zero-trust tie added).

Not fixed in this pass (out of scope, flagged for a future pass or operator decision):

- §11.4.168 Mermaid→pandoc HTML/PDF rendering (build-tooling fix, not a markdown-content fix).
- The v03-control-plane/svc-coordinator.md §10.1 fan-out-vs-graph-apply open design question (needs a Phase-2 spike, not a documentation decision).
- .html/.pdf sibling regeneration for every touched .md (export-pipeline work, out of scope for this pass per the task's explicit instruction to touch only source Markdown).
- The deferred deliverables below (unchanged by this pass).

Deferred deliverables (post-refinement, already agreed)

- Reusable-component **vasic-digital repos** (GitHub+GitLab) + submodules + upstreams/ + install_upstreams — created AFTER the spec stabilizes (operator decision 2026-06-25).
- **Workable-items SQLite DB** (§11.4.93) populated from the WBS stable IDs (HVPN-P0/1/2/3-NNN)
 - **docs_chain** wiring (§11.4.106).
- **Export formats** (HTML/PDF/DOCX) for the whole spec set + Mermaid→image rendering with §11.4.168 visual validation.